CVEs más relevantes de la semana

Del 27/10/2026 al 03/11/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2026-118333

Descripción: Missing authorization in Video in Google Chrome prior to 156.0.8078.73 allowed a remote attacker to bypass web origin policy via a crafted HTML page. (Chromium security severity: High)

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-10-27

CVE-2026-118337

Descripción: Improper access control in Forms in Google Chrome prior to 156.0.8078.73 allowed a remote attacker to bypass web origin policy via a crafted HTML page. (Chromium security severity: High)

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:N

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-10-27

CVE-2026-103406

Descripción: An Improper Neutralization of Special Elements used in an OS Command vulnerability in the AutomatedProvisioner in Juniper Networks Session Smart Conductor allows a remote attacker to execute arbitrary commands as root via a specially crafted salt minion ID.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-10-28

CVE-2026-103409

Descripción: A Missing authentication for critical function vulnerability in Juniper Networks Session Smart Router allows an unauthenticated network-based attacker to obtain administrative privileges by passing crafted URL parameters to an insecure endpoint running as root.

Note that this vulnerability can only be exploited prior to the device being onboarded to Mist/Conductor. The issue can no longer be e...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-10-28

CVE-2026-104317

Descripción: IBM Langflow OSS 1.0.0 through 1.12.3 could allow a remote attacker who could reach the message broker to execute arbitrary code on the system due to the deserialization of untrusted data.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-10-29

CVE-2026-18894

Descripción: IBM Langflow OSS 1.0.0 through 1.12.4 could allow a remote attacker to trigger pre-existing stored Python component code in a public workflow, executing it under the flow owner's runtime context within the server process. This bypasses the intended trust boundary where public execution paths are restricted to server-trusted component code.

CVSS: 6.5 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-10-29

CVE-2026-64618

Descripción: Improper Neutralization of Special Elements used in an SQL Command ("SQL Injection") vulnerability exists in Apache Fineract (through version 1.15.0). The vulnerability affects the outStandingAmountPercentageCondition parameter of the /fineract-provider/api/v1/search/advance HTTP API endpoint, allowing SQL injection due to insufficient input neutralization. Users are recommended to upgrade to v...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-10-30

CVE-2026-119597

Descripción: OpenDeepWiki through 2.0.6 contains a hard-coded JWT signing key vulnerability that allows unauthenticated attackers to forge administrator tokens using the publicly known Jwt:SecretKey in appsettings.json. Attackers can mint HS256 bearer tokens with an Admin role claim to access /api/admin endpoints and control users, roles, repositories, settings, and API keys.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-321

Tecnología: No especificado

Publicado el: 2026-10-30

CVE-2026-119660

Descripción: MuseBot before 2.0.0 contains an authentication bypass vulnerability that allows unauthenticated attackers to forge admin sessions by using the hard-coded default session_key 'muse_bot_session_key'. Attackers can sign a MuseBot-session cookie carrying a user_id to gain full administrative access, reading password hashes, chat records, and bot configuration, and stopping bots.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1394

Tecnología: No especificado

Publicado el: 2026-10-30

CVE-2026-119706

Descripción: InternLM LMDeploy 0.9.0 through 0.18.0 contains an unauthenticated remote code execution vulnerability that allows remote attackers to run OS commands by sending pickled data to the /update_weights endpoint. Attackers can submit a base64-encoded crafted pickle in serialized_named_tensors, which ForkingPickler.loads deserializes without validation, executing commands as the api_server process.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-10-30

CVE-2026-119716

Descripción: pybars3 through 0.9.7 and pybars4 through 0.9.13 contain a code injection vulnerability in pybars/_compiler.py that allows template authors to execute Python code via unescaped bracketed path segments. Attackers can supply Handlebars templates with crafted segments in helper or block arguments to break out of string literals and execute Python in the application process.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-10-30

CVE-2026-116557

Descripción: The WP Booking System - Booking Calendar plugin for WordPress is vulnerable to unauthorized modification of data due to a missing capability check on the wpbs_action_ajax_calendar_remove_note() function in versions up to, and including, 2.1.0.5 This makes it possible for authenticated attackers, with Subscriber-level access and above, to delete arbitrary calendar notes belonging to any calendar.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-10-31

CVE-2026-103882

Descripción: The Acadlix LMS – AI Quiz Maker, Online Exam & Course Plugin for WordPress plugin for WordPress is vulnerable to arbitrary file deletion due to insufficient file path validation in the post_delete_assessment_file_by_id function in all versions up to, and including, 1.1.9. This makes it possible for authenticated attackers, with subscriber-level access and above, to delete arbitrary files on the...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-10-31

CVE-2026-120189

Descripción: A vulnerability was identified in D-Link DIR-505 1.10B02. Affected is the function save_upload_file/mp_upload_file of the file /usr/bin/tftpd of the component TFTP Upload Filename Handler. The manipulation leads to stack-based buffer overflow. The attack is possible to be carried out remotely. The exploit is publicly available and might be used.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-11-01

CVE-2026-120195

Descripción: A security vulnerability has been detected in WAVLINK WL-WN579A3-A 2026-03-10-94f93d4. The impacted element is the function set_wzdgwMesh of the file /cgi-bin/adm.cgi of the component Initial Setup Wizard. The manipulation of the argument wlan_ssid leads to os command injection. The attack is possible to be carried out remotely. The exploit has been disclosed publicly and may be used. The vendo...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-01

CVE-2026-120196

Descripción: A vulnerability was detected in WAVLINK WN579X3-D V250402. This affects the function port_forward of the file /cgi-bin/wapi.cgi. The manipulation of the argument Name results in os command injection. The attack may be performed from remote. The exploit is now public and may be used. The vendor was contacted early about this disclosure.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-01

CVE-2026-120225

Descripción: A weakness has been identified in Oray Pugongying X5 Pro up to 7.6.1. Affected by this vulnerability is the function config_restore_ex of the file /etc/openwrt_release. This manipulation of the argument filename causes relative path traversal. The attack may be initiated remotely. The exploit has been made available to the public and could be used for attacks. The vendor was contacted early abo...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-11-01

CVE-2026-120229

Descripción: A vulnerability has been found in WAVLINK WN553X1-B 260403_2.0.0. This issue affects the function sub_416B50 of the file /bin/ioos. The manipulation of the argument file_id leads to os command injection. The attack is possible to be carried out remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-01

CVE-2026-120230

Descripción: A vulnerability was found in WAVLINK WN701AE 260105. Impacted is the function del_vlan_group of the component ioos Web Backend. The manipulation of the argument vlan_name results in os command injection. The attack may be performed from remote. The exploit has been made public and could be used. The vendor was contacted early about this disclosure.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-01

CVE-2026-120238

Descripción: A vulnerability has been found in WAVLINK WN553X1-B 260403_2.0.0. This affects the function sub_4162A8 of the file /bin/ioos of the component ovpn_file Handler. Such manipulation of the argument file_id leads to os command injection. The attack can be executed remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure.

CVSS: 9.9 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-01

CVE-2026-120276

Descripción: A weakness has been identified in WAVLINK WN536AX6-A V260507_2.0.0. This vulnerability affects the function sub_416760 of the file /bin/ioos of the component Web Management Interface. This manipulation of the argument group_name causes os command injection. It is possible to initiate the attack remotely. The exploit has been made available to the public and could be used for attacks. The vendor...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-02

CVE-2026-120277

Descripción: A security vulnerability has been detected in WAVLINK WN536AX6-A V260507_2.0.0. This issue affects the function sub_41a1d8 of the file /bin/ioos of the component WireGuard CLI Group Handler. Such manipulation of the argument group_name leads to os command injection. It is possible to launch the attack remotely. The exploit has been disclosed publicly and may be used. The vendor was contacted ea...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-02

CVE-2026-120280

Descripción: A vulnerability has been found in WAVLINK WN536AX6-A V260507. The impacted element is the function wireguard_cli_group handler of the file /protocol.csp of the component WireGuard. The manipulation of the argument group_id/group_name leads to os command injection. The attack may be initiated remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early a...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-02

CVE-2026-120281

Descripción: A vulnerability was found in WAVLINK WN536AX6-A V260507. This affects the function strcpy of the file /protocol.csp of the component OpenVPN Handler. The manipulation of the argument openvpn_ip results in stack-based buffer overflow. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was contacted early about this disclosure.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-11-02

CVE-2026-120345

Descripción: A vulnerability was found in WAVLINK WN551X3-A M51X3_V251020-WO-182e965. This impacts the function sub_41a430 of the file /bin/ioos of the component DNS Resolution Handler. Performing a manipulation of the argument data results in os command injection. It is possible to initiate the attack remotely. The exploit has been made public and could be used. The vendor was contacted early about this di...

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-11-02

CVE-2026-120442

Descripción: ape-volo-admin before 3.6.1 contains an authentication bypass vulnerability that allows unauthenticated attackers to forge administrator tokens using a hardcoded JWT signing key in appsettings.json. Attackers can sign tokens offline with the jti claim set to the seeded administrator id to gain full API control over users, roles, permissions and data.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-1394

Tecnología: No especificado

Publicado el: 2026-11-02

CVE-2026-120446

Descripción: madong-admin-saas through 5.1.4 contains a missing authentication vulnerability in the platform tenant management API because the 'platformapi' middleware key never matches the 'platform' application. Unauthenticated remote attackers can call /platformapi/tenant/account, bind-plan and sync-data endpoints to list, create, modify, disable or delete tenants and bind subscription plans.

CVSS: 9.4 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-11-02

CVE-2026-86596

Descripción: The s2Member plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, <= 260927 via the 'item_name' parameter parameter. This is due to insufficient sanitization in strip_php_tags_deep(), which only strips literal '<?' sequences, combined with a post-interpolation placeholder cleanup that reassembles a valid '<?php' opener after the attacker-controlled v...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-11-02

CVE-2026-120518

Descripción: The BuddyPress XProfile Image Field plugin for WordPress is vulnerable to arbitrary file deletion in all versions up to, and including, 3.1.0. This is due to bpxp_image_field_update_on_user_activation() calling unlink() on a path built from visitor-supplied signup metadata with no realpath() resolution, no containment check against the profile-image directory and no extension allow-list. Submit...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-11-03



Resumen del Reporte

CVEs analizados: 29

Promedio CVSS: 9.52

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat

